

Межсхемное взаимодействие

При обработке данных из разных клиентских схем могут возникать проблемы безопасности. Это актуально для сервисов, где одна база данных обслуживает множество клиентов, и методы принимают в качестве параметра идентификаторы клиента или пользователя. Отсутствие должного контроля приводит к риску утечек и несанкционированного изменения данных.

Методы работы с данными клиента, например, отправки событий или управления интеграциями, обрабатывали запросы без проверки принадлежности идентификатора к текущей схеме. Это позволяло злоумышленнику, передав идентификатор другого клиента, получить доступ к чужим данным или изменять их.

Как это выглядит:

1. Злоумышленник из схемы "А" делает запрос с id клиента из схемы "Б".
2. Если проверка схемы не настроена, сервер обрабатывает запрос, что позволяет манипулировать данными клиента "Б".

Пример:

Метод `ConnectionInterface.Read` позволяет получить информацию об интеграциях из чужих схем за счет перебора целочисленного идентификатора, если не реализована дополнительная проверка прав.

```
vi.razu@usd-bazenix1 ~/w/hurl> cat ConnectionInterface/ConnectionInterface.Read.turl | rg -c 3 password
  "params": {
    "data": {
      "id": { "mazo-id": "██████████" },
      "s": [ { "n": "login", "t": "Строка", { "m": "password", "q": "Строка" } } ]
    }
  },
  "protocol": 6,
vi.razu@usd-bazenix1 ~/w/hurl> hurl --proxy socks://127.0.0.1:5555 --variable id=3541 ConnectionInterface/ConnectionInterface.Read.turl | jq-record
{
  "next_connection": 3541,
  "account": 3,
  "acc_billing": ,
  "id": "4109c80d-833a-4375-bf2c-8533c067a568",
  "suspend": false,
  "settings": { "create_new_users": true, "device_root_path": "\\\\umglichskae,ourworkstations,ourcomputeraccounts,dc=corp,dc=tensor,dc=ru\\", "domain": "tensor-corp\\", "login": "sols3-ad-auth\\", "re
les_root_path": "\\\\.", "root_path": "\\\\ourserveraccounts,dc=corp,dc=tensor,dc=ru\\", "server": "dcl.corp.tensor.ru\\", "state": true, "update_user_structure": true },
  "name": "IDICOP\\IDICOP\\IDICOP",
  "unle_key": ,
  "sync_start": ,
  "sync_id": ,
  "sync_type": ,
  "app": 26,
  "schema": 46,
  "ctid": "(17,4)"
}
```

в скрипте запрос делается от имени моего пользователя с собственной схемой

целочисленный id, можно перебирать

при этом получили информацию об интеграции из 3й схемы (Тензор)

Избежать таких ошибок можно, если:

1. Реализована проверка принадлежности данных текущей схеме.

Метод должен проверять, что id клиента, переданный в запросе, принадлежит текущей схеме пользователя. Если это не так, запрос должен быть отклонен.

2. Использовать идентификаторы из сессии.

Если метод API требует идентификатор клиента или пользователя, берите его из текущей сессии, а не из параметров запроса. Это исключит возможность подмены идентификатора злоумышленником.

3. Реализуйте межсхемный барьер.

Настройте изоляцию данных в базе. Методы API должны возвращать только данные текущей схемы.